

Incident Analysis Report: Malware Infection via Unauthorized USB Device

Project Information

Organization: SwiftCart Logistics Ltd

Assessment Type: Security Hardening Assessment Using the NIST Cybersecurity Framework (CSF)

Incident Category: Malware Infection / Endpoint Compromise

Severity Level: High

Prepared By: Justin Gabriel

Date: June 2026

Executive Summary

As part of the security hardening assessment conducted for SwiftCart Logistics Ltd, a malware infection scenario involving an unauthorized USB device was analysed to assess the organization's ability to prevent, detect, respond to, and recover from endpoint-based threats.

The assessment focused on a realistic situation where an employee introduced malware into the corporate environment through a personal USB storage device. Although the incident remained contained to a single workstation in this scenario, the investigation revealed weaknesses in endpoint security controls, device management, monitoring capabilities, and user awareness that could allow malware to spread throughout the organization's network.

The purpose of this report is to document the incident lifecycle, identify contributing factors, evaluate business impact, and recommend security improvements aligned with the NIST Cybersecurity Framework.

Organizational Background

SwiftCart Logistics Ltd operates several warehouses and logistics centres across East Africa. Warehouse operations depend heavily on digital systems for inventory management, shipment tracking, and communication with customers and suppliers.

Employees regularly interact with inventory spreadsheets, shipping manifests, and operational reports. Due to operational demands, warehouse personnel occasionally transfer files between systems using removable media.

While convenient, removable media introduces security risks because files can be transferred directly into corporate environments without passing through many of the controls that inspect internet-based traffic.

This makes USB devices an attractive malware delivery mechanism for attackers.

Incident Overview

Incident Description

A warehouse supervisor used a personal USB flash drive to transfer inventory reports from a home computer to a company workstation.

Unknown to the employee, the USB drive had previously been connected to an infected personal device and contained a malicious executable disguised as a spreadsheet utility.

Upon connecting the USB device to the corporate workstation, the employee launched the malicious file believing it was required to view the transferred reports.

The malware executed successfully and began performing several actions designed to establish persistence, evade detection, and communicate with an external command-and-control server.

Attack Timeline

Phase 1: Introduction of Malware

The employee connected an unmanaged USB storage device to a company workstation.

Because no device control policies were enforced, the operating system allowed unrestricted access to the contents of the device.

This provided the malware with an entry point into the corporate environment.

Phase 2: Malware Execution

The employee executed a file named:

Inventory_Report_Tool.exe

The filename was intentionally chosen to appear legitimate and relevant to warehouse operations.

Social engineering techniques often rely on convincing users that malicious files serve a legitimate business purpose.

Once executed, the malware launched silently in the background.

Phase 3: Persistence Establishment

After execution, the malware modified system settings to ensure it would automatically start whenever the computer rebooted.

The malware created:

- Registry start-up entries
- Scheduled tasks
- Hidden files within user directories

Persistence mechanisms allow attackers to maintain access even after a system restart.

Without persistence, malware may be removed simply by rebooting the device.

Phase 4: Command and Control Communication

The malware attempted to establish communication with an external server controlled by the attacker.

The purpose of this connection was to:

- Receive commands
- Download additional payloads
- Exfiltrate data
- Maintain remote access

Outbound network communication is a common behaviour associated with modern malware infections.

Phase 5: Discovery and Detection

Microsoft Defender detected unusual behaviour involving:

- Encoded PowerShell commands
- Unauthorized process execution
- Suspicious network activity

These alerts triggered an investigation by the security team.

Early detection significantly reduced the likelihood of malware spreading to other systems.

Indicators of Compromise

Several indicators suggested endpoint compromise.

1. Suspicious Process Creation

System logs showed execution of a previously unknown executable originating from removable media.

Files launched directly from USB devices warrant investigation because they bypass many normal software deployment processes.

2. Encoded PowerShell Commands

Windows logs revealed PowerShell commands containing encoded content.

Attackers frequently use encoded commands to:

- Obscure malicious actions
- Evade detection
- Execute payloads

Encoded PowerShell activity should always be treated as suspicious unless clearly justified.

3. Unusual Network Connections

The infected workstation attempted outbound communication with previously unseen external IP addresses.

These connections did not align with normal business operations.

Unexpected outbound traffic often indicates malware attempting to communicate with attacker infrastructure.

4. Registry Modifications

The malware created start-up registry entries shortly after execution.

Unauthorized persistence mechanisms are commonly used to survive system reboots and maintain long-term access.

5. Microsoft Defender Alerts

Multiple endpoint protection alerts identified:

- Suspicious behaviour patterns
- Malware execution attempts
- Potential command-and-control communication

These alerts provided the initial evidence that an endpoint compromise had occurred.

Investigation Process

1. Initial Triage

The investigation began after Microsoft Defender generated a high-severity alert relating to suspicious PowerShell activity.

The primary objective during triage was determining whether the alert represented malicious behaviour or legitimate administrative activity.

Security analysts reviewed:

- Defender alerts
- Endpoint logs
- PowerShell activity
- User activity records

Initial findings indicated behaviour consistent with malware execution.

2. Endpoint Isolation

Once compromise was suspected, the workstation was immediately isolated from the network.

Isolation serves several important purposes:

- Prevents malware spread
- Stops command-and-control communication
- Preserves evidence
- Reduces organizational risk

Containment is often the highest priority during malware investigations.

3. User Interview

The affected employee was interviewed to establish a timeline of events.

The employee confirmed:

- A personal USB device had been connected
- Files were copied from the device
- A program had been executed shortly before alerts appeared

This information helped investigators identify the likely infection vector.

4. Log Analysis

Security analysts examined multiple log sources.

a) Windows Event Logs

Investigators reviewed:

- Process creation events
- Service creation events
- Authentication events

These logs provided visibility into system activity before and after compromise.

b) Microsoft Defender Logs

Defender telemetry was used to identify:

- Malware behaviour
- Detection timestamps
- Process lineage
- Threat classifications

Understanding how the malware behaved helped determine the scope of the incident.

c) PowerShell Logs

PowerShell logs revealed encoded commands attempting to download additional content from external infrastructure.

This suggested the initial malware was acting as a loader for secondary payloads.

d) Network Logs

Network traffic analysis identified attempted communication with suspicious external hosts. Investigators verified whether additional systems had contacted the same destinations. Fortunately, no evidence of lateral movement was identified.

Scope Assessment

A critical objective of the investigation was determining whether the infection had spread beyond the original workstation.

The following questions guided the assessment.

1. Were Additional Endpoints Affected?

Endpoint telemetry from neighbouring systems was reviewed. No indicators of compromise were identified on other devices.

2. Was Sensitive Data Accessed?

Investigators reviewed file access activity and network traffic. No evidence suggested successful data exfiltration.

However, the attempted external communications demonstrated that such activity was possible.

3. Did the Malware Spread Laterally?

Authentication logs and endpoint activity were examined for signs of movement between systems.

No unauthorized access attempts were detected.

Early isolation likely prevented lateral movement.

Impact Assessment

1. Confidentiality Impact

Medium

Although no confirmed data theft occurred, the malware attempted external communication and could have enabled future information disclosure.

2. Integrity Impact

Medium

The malware modified system settings and established persistence mechanisms.

These actions altered the workstation's operating environment.

3. Availability Impact

Medium

The workstation required isolation and remediation, temporarily affecting employee productivity.

A more advanced malware variant could have disrupted business operations on a larger scale.

Overall Risk Rating

High

The incident involved active malware execution, persistence establishment, and attempted communication with external infrastructure.

Had detection been delayed, the organization could have faced broader compromise.

Root Cause Analysis

Several factors contributed to the success of the infection.

1. Lack of USB Device Control Policies

The organization allowed unrestricted use of removable media.

This created an opportunity for unmanaged devices to introduce malicious content into the environment.

Restricting USB usage significantly reduces this attack vector.

2. Inadequate Application Control

The malicious executable was allowed to run without restriction.

Application allow listing could have prevented unauthorized software execution.

3. Insufficient User Awareness

The employee executed an unfamiliar program without verifying its legitimacy.

User awareness training should encourage employees to question unexpected software and report suspicious files.

4. Limited Endpoint Hardening

Additional restrictions on script execution and software installation could have reduced malware effectiveness.

Layered controls provide multiple opportunities to stop attacks before they succeed.

Containment Actions

Several immediate actions were performed following confirmation of compromise.

1. Network Isolation

The affected workstation was removed from the network.

This prevented communication with attacker infrastructure and reduced the risk of spread.

2. USB Device Seizure

The USB device was removed and preserved for analysis.

Examining the source device may provide additional information regarding the infection vector.

3. Malware Quarantine

Detected malicious files were quarantined using endpoint protection tools.

This prevented further execution of known malicious components.

4. Credential Review

User credentials associated with the workstation were reviewed and reset as a precautionary measure.

Certain malware families are capable of credential theft.

Recovery Actions

1. System Reimaging

The workstation was rebuilt using a known-good operating system image.

Reimaging provides greater assurance than attempting manual malware removal.

2. Security Validation

The rebuilt system was verified to ensure:

- No malicious files remained
- Security controls were functioning
- Monitoring capabilities were operational

3. Restoration of Business Operations

Required business applications and approved files were restored.

The employee regained access to normal operational systems following validation.

Lessons Learned

Several important lessons emerged from this incident.

1. Removable media remains a viable attack vector.

Many organizations focus heavily on internet threats while underestimating risks introduced through physical devices.

2. Endpoint detection is critical.

Without Defender alerts, the malware may have remained active for an extended period.

Detection capabilities significantly reduce attacker dwell time.

3. User behaviour influences security outcomes.

Technology alone cannot eliminate risk.

Employees must understand how their actions affect organizational security.

4. Early containment limits impact.

Rapid isolation prevented the malware from spreading to additional systems.

The speed of containment directly influenced the outcome of the incident.

Security Hardening Recommendations

Priority 1 Recommendations

1. Implement USB Device Control Policies

Only approved removable media should be permitted within the environment.

Unauthorized devices should be blocked automatically.

2. Deploy Application Allow listing

Only approved software should be allowed to execute on corporate endpoints.

This significantly reduces the risk of malware execution.

3. Strengthen Endpoint Protection

Advanced endpoint detection and response capabilities should be deployed across all systems.

Improved visibility enhances detection and response effectiveness.

Priority 2 Recommendations

1. Enable Enhanced PowerShell Logging

Detailed PowerShell logging improves visibility into attacker activity and assists future investigations.

2. Centralize Log Collection

Security logs should be aggregated into a centralized monitoring platform.

This improves correlation, investigation, and alerting capabilities.

3. Conduct Security Awareness Training

Employees should receive guidance regarding:

- USB security
- Social engineering
- Suspicious files
- Reporting procedures

Priority 3 Recommendations

1. Perform Endpoint Security Audits

Regular reviews should validate that hardening measures remain effective and properly configured.

2. Conduct Malware Response Exercises

Practical exercises improve analyst readiness and incident response coordination.

MITRE ATT&CK Mapping

Technique ID	Technique Name	Observed Activity
T1204	User Execution	User launched malicious executable
T1059.001	PowerShell	Encoded PowerShell commands executed
T1547	Boot or Logon Autostart Execution	Registry persistence created
T1105	Ingress Tool Transfer	Malware attempted payload retrieval
T1071	Application Layer Protocol	Command and control communication
T1082	System Information Discovery	Malware collected system information

NIST Cybersecurity Framework Mapping

IDENTIFY

The organization must identify:

- Critical endpoints
- Approved devices
- High-risk user groups
- Sensitive operational systems

Organizations cannot effectively protect assets they do not understand or inventory.

PROTECT

Recommended protective controls include:

- USB device restrictions
- Application allow listing
- Endpoint hardening
- Security awareness training
- Least privilege access

These controls reduce the likelihood of malware successfully executing.

DETECT

Detection capabilities should include:

- Endpoint monitoring
- PowerShell logging
- Defender alerting
- Network traffic analysis
- Persistence monitoring

The objective is to identify malicious activity before significant damage occurs.

RESPOND

Response procedures should address:

- Endpoint isolation
- Malware containment
- Evidence preservation
- Escalation procedures
- Communication requirements

A structured response minimizes confusion and accelerates recovery.

RECOVER

Recovery activities should include:

- Secure workstation rebuilding
- Validation testing
- User re-enablement
- Post-incident reviews
- Continuous improvement initiatives

Recovery should not only restore operations but also reduce the likelihood of future compromise.